

Architettura di Data Governance e Knowledge Management

Piattaforma a supporto di progetti AI governati, tracciabili e riproducibili

Studio di progettazione di una piattaforma aziendale di Data Governance e Knowledge Management per NovaCura Pharma: catalogo, metadati, lineage, policy, knowledge graph e un flusso RAG governato che rendono i progetti di AI sicuri, tracciabili e riproducibili, con la stessa infrastruttura che soddisfa il regolatore e accelera la R&D, dimostrata con artefatti SQL e Big Data su un caso di drug repurposing per malattie rare.

Simone La Porta

Master AI Solutions Architect - ProfessionAI

Indice

1. Executive summary	4
2. Nota metodologica	4
3. Contesto e caso d'uso	5
3.1 Profilo di NovaCura Pharma	5
3.2 Il caso guida: un programma di drug repurposing	5
3.3 Obiettivi di business e valore	5
4. Requisiti	6
4.1 Requisiti funzionali	6
4.2 Requisiti non funzionali	7
5. Quadro normativo e data integrity	7
6. Architettura logica della piattaforma	9
6.1 Visione d'insieme	9
6.2 Domini funzionali	9
6.3 Relazioni tra domini	10
6.4 Matrice di copertura requisiti - domini	11
7. Data catalog e metadata management	12
7.1 La scheda di dataset	12
7.2 Il modello di metadati	13
7.3 Vocabolari controllati e tag semantici	14
7.4 Il ciclo di vita del dato	15
8. Data lineage e riproducibilità	16
8.1 Il modello a grafo	16
8.2 Ricostruzione e riproducibilità	17
9. Policy di data governance	17
9.1 Classificazione e accesso	18
9.2 Conservazione, privacy e condivisione	18
9.3 Ruoli e responsabilità	19
10. Knowledge graph di dominio	19
10.1 Entità, relazioni ed evidenza reificata	20
10.2 Governance del grafo	21
11. Flusso RAG governato	21
12. Audit, data quality e reportistica	22
12.1 Data quality sulle sei dimensioni	22
12.2 Audit trail 21 CFR Part 11	23
13. Supporto SQL e Big Data	23
13.1 Artefatti SQL	23
13.2 Specifiche Big Data	24
14. Modello di maturità e roadmap di adozione	26
15. Rischi e mitigazioni	27
17. Appendici	27

Appendice A - Glossario	27
Appendice B - Riferimenti normativi e standard	28
Appendice C - Inventario degli artefatti e repository	28
Appendice D - Assunzioni	29

1. Executive summary

NovaCura Pharma sviluppa terapie per malattie rare e conduce studi clinici internazionali. Il progetto progetta una piattaforma di Data Governance e Knowledge Management a livello aziendale che permetta di sostenere, in modo sicuro e riproducibile, i progetti di AI dell'azienda: discovery, farmacovigilanza, arruolamento, stratificazione dei soggetti. Il caso guida su cui la piattaforma viene dimensionata è un programma di drug repurposing che integra quattro famiglie di fonti eterogenee: studi clinici interni, dataset di laboratorio (assay), annotazioni dalla letteratura e report di farmacovigilanza.

Il problema non è la mancanza di dati, ma la mancanza di governo sui dati. Senza catalogo, metadati, lineage e policy, un modello che aggrega evidenze per un candidato farmaco produce un risultato che nessuno può verificare, riprodurre o difendere davanti a un regolatore. In un contesto GxP questo non degrada la qualità del risultato: blocca il progetto. La piattaforma risponde con cinque capacità che si tengono a vicenda: un catalogo con metadati ricchi che rende i dati trovabili e riutilizzabili; un tracciamento del lineage che rende ogni risultato ricostruibile dai dati grezzi; un insieme di policy che governa classificazione, accesso, conservazione e privacy; un knowledge graph di dominio che collega entità biomediche ed evidenze; un flusso RAG governato che genera documentazione contestuale citando sempre la fonte.

L'impianto è volutamente una specifica progettuale, non una implementazione operativa. La consegna include documentazione tecnica, artefatti SQL eseguibili (catalogo, metadati, lineage, audit trail, query di validazione e di ricostruzione), specifiche Big Data (partizionamento, manifest, pseudocodice di pipeline), un modello concettuale di knowledge graph con un campione di triple, e la specifica funzionale del flusso RAG. Gli artefatti SQL sono stati verificati caricandoli ed eseguendoli su un motore PostgreSQL.

Il valore atteso per NovaCura si distribuisce su cinque assi: compliance regolatoria (tracciabilità e auditabilità di dataset e workflow AI), accelerazione della R&D (ricerca dati più rapida e riuso della conoscenza interna), fiducia nei modelli (dati governati e lineage migliorano riproducibilità e affidabilità), riduzione del rischio (gestione centralizzata di accessi e conservazione dei dati sensibili) e valore strategico (un patrimonio conoscitivo riutilizzabile).

2. Nota metodologica

Natura del documento e dei dati

Questo è uno studio di progettazione, non un sistema in esercizio. L'azienda NovaCura Pharma è fittizia; nomi di dataset, valori, codici e il caso di repurposing usato come esempio (sirolimus per la linfangioleiomiomatosi) sono illustrativi e servono a rendere le specifiche concrete e gli artefatti eseguibili. Nessun dato reale di pazienti o di studio è coinvolto. I codici di vocabolario (ChEMBL, Orphanet, UniProt, MedDRA) sono reali e usati per mostrare l'interoperabilità, ma le relazioni nel grafo di esempio sono costruite per l'illustrazione. Ogni scelta di design è accompagnata dalla sua motivazione e da una lettura critica dei suoi limiti; nessuna parte va letta come raccomandazione di prodotto o come configurazione pronta alla produzione.

Il perimetro segue la traccia. Sono inclusi: catalogazione e metadattazione dei dataset R&D rilevanti; policy di governance; specifica logica del lineage end-to-end; modello concettuale di knowledge graph; specifica funzionale del flusso RAG; artefatti SQL e Big Data. Sono esclusi: l'implementazione operativa in produzione, la

scelta e configurazione di prodotti specifici, e il training operativo degli utenti oltre alla documentazione progettuale.

3. Contesto e caso d'uso

3.1 Profilo di NovaCura Pharma

NovaCura Pharma è una società farmaceutica orientata alla ricerca e sviluppo di terapie per malattie rare e alla conduzione di studi clinici internazionali. Il focus sulle malattie rare ha una conseguenza diretta sul dato: le popolazioni di studio sono piccole, ogni soggetto pesa, e il riuso di conoscenza tra programmi diversi non è un lusso ma una necessità. Il repurposing di molecole già note è, in questo contesto, una delle strategie a più alto rendimento: parte da composti con un profilo di sicurezza già caratterizzato e cerca nuove indicazioni.

3.2 Il caso guida: un programma di drug repurposing

L'obiettivo concreto è supportare un programma che, per un candidato farmaco, deve saper fare tre cose: ricercare e aggregare le evidenze rilevanti; fornire spiegazioni contestuali delle decisioni (provenienza dei dati, estratti testuali, relazioni tra entità); consentire un audit completo della pipeline dai dati grezzi al risultato finale, per scopi regolatori. Le quattro famiglie di fonti che il programma integra sono la spina dorsale di tutta l'architettura che segue.

Fonte	Contenuto	Sensibilità	Sistema sorgente
Studi clinici	Esiti, endpoint, bracci per soggetto	Restricted (PHI)	CTMS (validato)
Laboratorio (assay)	Potenza, affinità, tossicità per composto-target	Confidential	LIMS (validato)
Letteratura	Relazioni farmaco-malattia-target estratte	Public / Internal	Servizio di ingestione
Farmacovigilanza	Reazioni avverse codificate MedDRA (ICSR)	Restricted (PHI)	Safety DB (validato)

Tabella 3.1 - Le quattro famiglie di fonti del programma di repurposing.

L'AI deve poter attraversare queste fonti in maniera coerente: trovare i composti che agiscono su un target coinvolto in una malattia rara, pesare le evidenze a favore e contro, controllare i segnali di sicurezza, e produrre un report che un ricercatore o un clinico possano verificare fino al dato originale. Questo richiede esattamente ciò che il modulo tratta: governance dei dati, metadati ricchi, lineage e un knowledge graph, con il RAG come canale di generazione della conoscenza.

3.3 Obiettivi di business e valore

Obiettivo	Cosa cambia	Indicatore di riferimento
Compliance regolatoria	Tracciabilità e auditabilità di dataset e workflow AI	% workflow con lineage ricostruibile

Obiettivo	Cosa cambia	Indicatore di riferimento
Accelerazione R&D	Ricerca dati più rapida, riuso della conoscenza interna	Tempo medio di ricerca evidenze
Fiducia nei modelli	Dati governati e provenienza migliorano la riproducibilità	% risultati riproducibili
Riduzione del rischio	Gestione centralizzata di accessi e conservazione	Incidenti di accesso / anno
Valore strategico	Patrimonio conoscitivo riutilizzabile (knowledge graph)	Entità e relazioni governate nel KG

Tabella 3.2 - Obiettivi e valore atteso per NovaCura.

Lettura critica. Gli obiettivi non sono indipendenti: la compliance regge sul lineage, il lineage rende auditabile la spiegabilità, la spiegabilità costruisce la fiducia. La tentazione, in un progetto pharma, è trattare la governance come adempimento e fermarsi alla compliance. La scelta di impianto qui è opposta: la stessa infrastruttura che soddisfa il regolatore (lineage, audit, provenienza) è quella che accelera la R&D, perché un dato tracciabile è anche un dato riutilizzabile.

4. Requisiti

4.1 Requisiti funzionali

I requisiti funzionali traducono le aree della traccia in capacità verificabili. Ciascuno riceve un identificatore che la matrice di copertura (paragrafo 6.4) lega ai domini funzionali della piattaforma.

ID	Requisito funzionale
RF-01	Scheda di catalogo per ogni dataset (nome, descrizione, owner, sensibilità, formato, campi, refresh, campioni)
RF-02	Standard minimo di metadati: definizione campi, semantica, tag semantici, versioning dei metadati
RF-03	Tracciamento del lineage: trasformazioni, tabelle sorgente, processi ETL/ELT, modelli consumatori
RF-04	Ricostruzione end-to-end dai dati grezzi al risultato del modello, per audit regolatorio
RF-05	Policy di classificazione, accesso, retention, privacy e data sharing, con mapping policy-dataset
RF-06	Modello concettuale di knowledge graph: entità cliniche, molecole, trial, endpoint e relazioni
RF-07	Flusso RAG governato: retrieval filtrato per accessi, selezione delle fonti, provenienza degli output
RF-08	Audit trail su accessi, modifiche ai metadati e processo di generazione dei risultati AI
RF-09	Artefatti SQL: query di validazione della qualità e della governance, query di trasformazione

ID	Requisito funzionale
RF-10	Schemi e specifiche Big Data: partizionamento logico, formati, manifest, pseudocodice di pipeline

Tabella 4.1 - Requisiti funzionali.

4.2 Requisiti non funzionali

Requisito	Cosa impone alla piattaforma
Scalabilità	Supportare crescita volumetrica e nuovi domini di dato senza cambio di schema (modello additivo)
Sicurezza e privacy	Protezione dei dati sensibili, segregazione dei ruoli, pseudonimizzazione dei dati a livello soggetto
Affidabilità e disponibilità	Livelli attesi di accessibilità delle risorse informative; transazioni ACID sui dataset GxP
Interoperabilità	Metadati e schemi coerenti; vocabolari standard come lingua comune tra team e strumenti
Manutenibilità	Versioning di dataset e metadati; evoluzione additiva; policy e soglie come dato, non come codice
Tracciabilità e auditabilità	Conservazione delle informazioni necessarie a ricostruire i processi a fini regolatori

Tabella 4.2 - Requisiti non funzionali.

Lettura critica. Tra i non funzionali, tracciabilità e sicurezza non sono qualità aggiuntive ma vincoli che plasmano l'architettura. La scelta di un audit trail append-only con catena hash (capitolo 12) o della pseudonimizzazione a monte del feature engineering (capitolo 13) nasce da questi requisiti, non da un'aggiunta successiva. Un requisito non funzionale che non cambia una decisione di design è un requisito decorativo.

5. Quadro normativo e data integrity

Ciò che rende il caso realistico è la cornice regolatoria. In una farmaceutica la governance del dato incontra un obbligo di legge, non solo una buona pratica. Le norme rilevanti per una piattaforma che sostiene progetti AI su dati clinici e di sicurezza si compongono in tre strati: le Good Practice (GxP) sul dato di studio, i requisiti sui record elettronici, e la protezione dei dati personali sanitari.

Riferimento	Cosa richiede	Come la piattaforma risponde
GxP (GCP/GLP/GMP)	Qualità e integrità del dato di studio clinico, di laboratorio e di produzione	DQ gate, classificazione GxP dei dataset, controlli di qualità per fase

Riferimento	Cosa richiede	Come la piattaforma risponde
21 CFR Part 11 (FDA)	Audit trail sicuro, firme elettroniche, record elettronici affidabili	Audit trail append-only con firma e significato, catena hash (cap. 12)
EU Annex 11	Controllo dei sistemi computerizzati GxP, tracciabilità delle modifiche	Log immutabile di modifiche a dati e metadati, versioning
GAMP 5	Approccio risk-based alla validazione dei sistemi computerizzati	Separazione control plane / data plane; specifica prima dell'implementazione
ALCOA+	Integrità del dato: Attributable, Legible, Contemporaneous, Original, Accurate, + Complete, Consistent, Enduring, Available	run tracciate con attore e timestamp, immutabilità, hash del manifest
GDPR art. 9	Trattamento delle categorie particolari (dati sanitari)	Pseudonimizzazione all'ingest, anonimizzazione per l'uso secondario, ACL
EU AI Act	Obblighi per i sistemi AI, tracciabilità e supervisione umana	Provenienza obbligatoria degli output, HITL, logging della generazione

Tabella 5.1 - Cornice normativa e risposta della piattaforma.

Il principio che tiene insieme lo strato regolatorio è la data integrity, sintetizzata dall'acronimo ALCOA+. Non è un vincolo astratto: ogni sua lettera si traduce in una decisione di schema, come mostra la tabella seguente.

Principio	Traduzione tecnica nella piattaforma
Attributable	Ogni evento di audit è legato a una persona identificata (mai anonima)
Legible / Original	Il Bronze conserva la copia fedele e immutabile della sorgente
Contemporaneous	Timestamp generato dal sistema al momento dell'evento
Accurate	DQ gate sulle sei dimensioni prima della promozione di stadio
Complete / Consistent	Transazioni ACID (Delta Lake): niente scritture parziali
Enduring / Available	Retention per categoria con base legale; archivio a freddo governato

Tabella 5.2 - ALCOA+ come requisiti di schema.

Lettura critica. La profondità normativa pharma-specific è una scelta deliberata rispetto a un generico richiamo a GDPR ed EU AI Act. La ragione è che 21 CFR Part 11, Annex 11 e ALCOA+ impongono requisiti concreti che cambiano lo schema (audit append-only, catena hash, versioning), mentre un richiamo generico resterebbe una dichiarazione di intenti. Il rischio opposto, la compliance-teatro, è reale: elencare norme senza tradurle in vincoli verificabili. Le tabelle 5.1 e 5.2 sono costruite proprio per evitarlo, legando ogni norma a un artefatto tecnico specifico.

6. Architettura logica della piattaforma

6.1 Visione d'insieme

L'architettura si legge a strati, dall'alto verso il basso: le quattro sorgenti alimentano un lakehouse organizzato in stadi di raffinamento (Bronze, Silver, Gold); sopra il Gold vive lo strato di conoscenza (knowledge graph e semantic layer); in cima, i consumatori (assistente RAG, scoring dei candidati, reportistica). A tenere insieme tutti gli strati corre, trasversale, la governance: catalogo, metadati, lineage, policy, controllo accessi e audit non sono un gate a valle ma un piano che attraversa ogni layer. È la lezione della nota sull'architettura dati: metadati e governance stanno sotto ogni stadio, non alla fine.

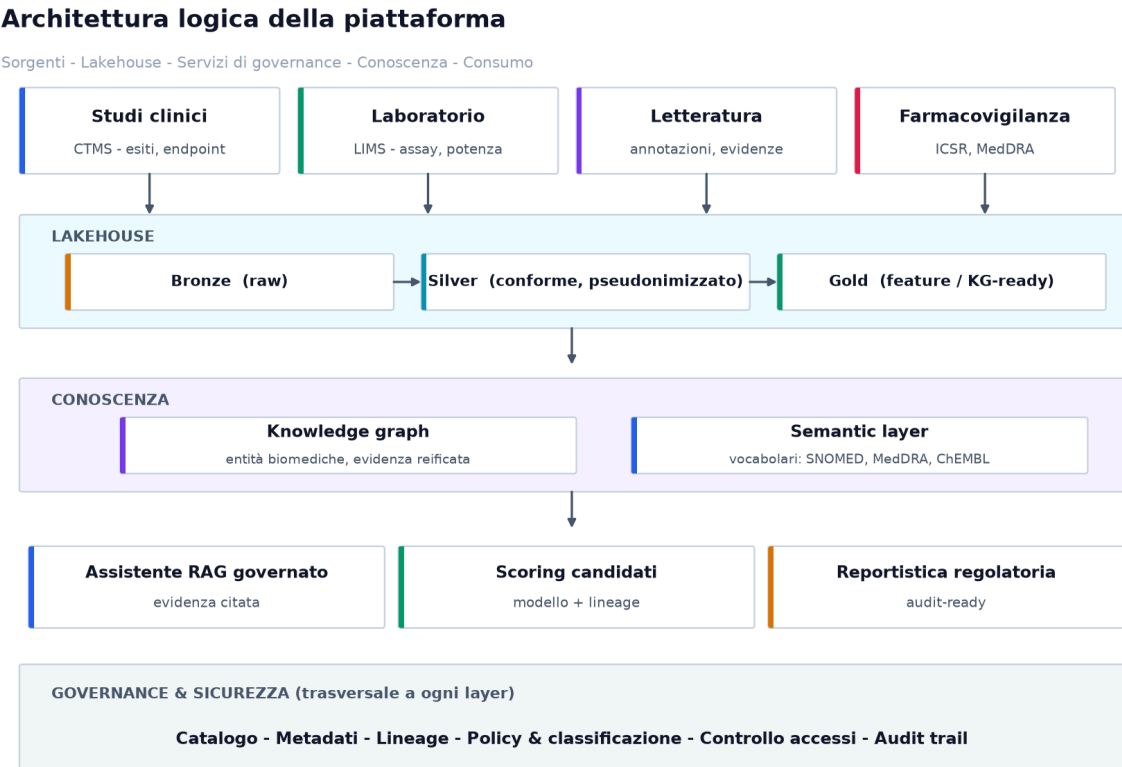


Figura 6.1 - Architettura logica: sorgenti, lakehouse, conoscenza, consumo, con la governance trasversale.

6.2 Domini funzionali

La governance trasversale si articola in otto domini funzionali. Ognuno è responsabile di una capacità e si aggancia agli artefatti concreti descritti nei capitoli seguenti.

Dominio	Responsabilità	Artefatti
D1 Catalogo & Metadati	Inventario dei dataset, scheda, standard di metadati, versioning	SQL 01, 02
D2 Data Quality	Sei dimensioni, soglie, scoring, profiling, DQ gate	SQL 05, manifest

Dominio	Responsabilità	Artefatti
D3 Lineage & Provenance	Grafo delle trasformazioni, ricostruzione end-to-end	SQL 03, 06
D4 Policy & Classificazione	Quattro livelli di sensibilità, mapping policy-dataset, retention	SQL 01
D5 Accessi & Sicurezza	RBAC, segregazione dei compiti, pseudonimizzazione	SQL 01, 04
D6 Knowledge Graph	Entità, ontologia, evidenza reificata con provenienza	KG model, triple
D7 RAG / Generazione	Retrieval filtrato, citazioni, grounding sul grafo	RAG spec
D8 Audit & Reporting	Audit trail 21 CFR Part 11, log della generazione AI	SQL 04

Tabella 6.1 - Gli otto domini funzionali.

Mappa dei domini di governance

Otto domini funzionali su una cornice regolatoria pharma-specific



Figura 6.2 - Mappa dei domini di governance sulla cornice regolatoria pharma.

6.3 Relazioni tra domini

Il catalogo (D1) è la base che tutti leggono: la classificazione di D4 vive nelle sue schede, il lineage di D3 estende le sue voci, la qualità di D2 misura i suoi dataset. Il controllo accessi (D5) legge la classificazione di D4 e alimenta l'audit di D8. Il knowledge graph (D6) è popolato dai dati Gold governati e interrogato dal RAG (D7), che a sua volta scrive nel log di generazione di D8. La catena di dipendenze è la stessa della nota di sintesi del modulo: l'ownership rende applicabile la classificazione, la classificazione rende significativo il lineage, il lineage rende auditabile la spiegabilità.

6.4 Matrice di copertura requisiti - domini

La matrice rende esplicito il legame tra i requisiti funzionali (paragrafo 4.1) e gli otto domini. Serve a due verifiche di completezza: nessun requisito resta scoperto, e nessun dominio è orfano rispetto ai requisiti.

RF	Requisito (sintesi)	D1	D2	D3	D4	D5	D6	D7	D8
RF-01	Scheda di catalogo	X							
RF-02	Standard metadati + versioning	X							
RF-03	Tracciamento lineage			X					
RF-04	Ricostruzione per audit			X					X
RF-05	Policy + classificazione				X	X			
RF-06	Knowledge graph						X		
RF-07	Flusso RAG governato					X		X	
RF-08	Audit trail					X			X
RF-09	Artefatti SQL di validazione		X	X					
RF-10	Schemi e specifiche Big Data	X	X						

Tabella 6.2 - Matrice di copertura requisiti funzionali - domini.

Ogni dominio compare in almeno un requisito e ogni requisito ha almeno un dominio responsabile. La lettura per colonna è utile in fase di revisione: il dominio D5 (accessi) compare in RF-05, RF-07 e RF-08, il che conferma che il controllo accessi non è confinato alle policy ma pervade retrieval e audit, come richiede la nota sul RAG governato.

Storage a strati: lakehouse medallion

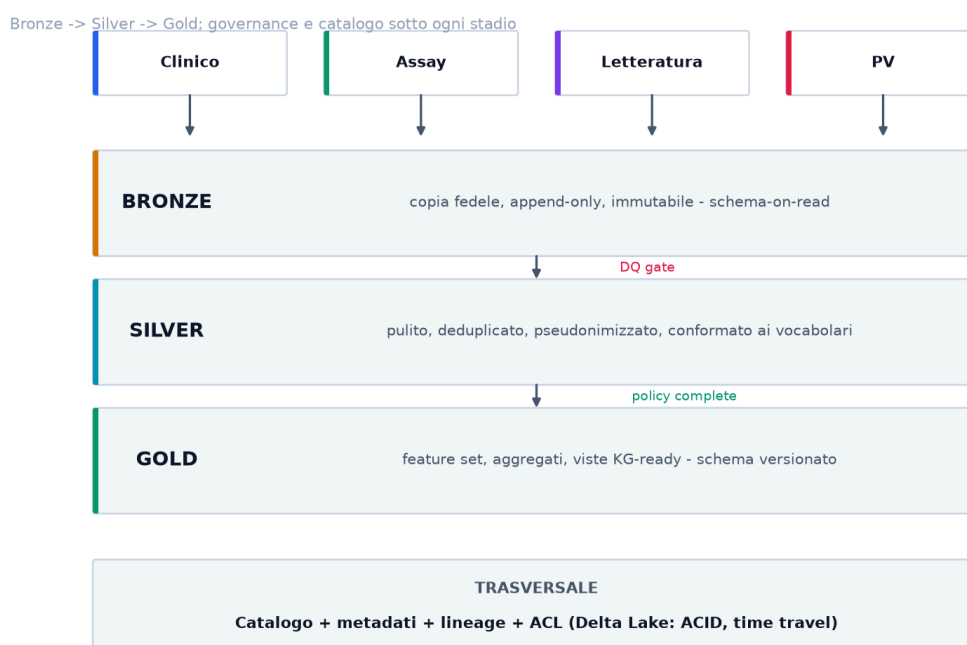


Figura 6.3 - Storage a strati (lakehouse medallion) con la governance sotto ogni stadio.

7. Data catalog e metadata management

Il catalogo è la vetrina che espone i dati; la gestione dei metadati è il motore che la riempie. Insieme trasformano un percorso di storage in un asset informativo: dicono cosa esiste, dove vive, chi ne risponde e come può essere usato. Senza catalogo, un file nel lakehouse è invisibile alla governance, e il dato invisibile è dove si annidano i gap di compliance.

7.1 La scheda di dataset

Ogni dataset ha una scheda (requisito RF-01) che ne fissa identità e responsabilità. La accountability è obbligatoria per costruzione: nello schema SQL (artefatto 01) owner e steward sono NOT NULL, la classificazione di sensibilità è obbligatoria. Un dataset senza proprietario o senza classificazione non entra in produzione, ed è proprio ciò che una delle query di validazione (artefatto 05) verifica.

Campo della scheda	Contenuto
Identità	URN stabile, nome, descrizione, dominio
Responsabilità	Data Owner, Data Steward, Data Custodian
Classificazione	Sensibilità (4 livelli), flag PHI, flag GxP
Fisico	Formato, location, stadio medallion, frequenza di refresh

Campo della scheda	Contenuto
Ciclo di vita	Stato (draft/active/archived/dismissed), versione di schema
Campioni	Link a un campione governato del dataset

Tabella 7.1 - Struttura della scheda di catalogo.

A titolo di esempio, la scheda compilata di uno dei dataset del caso guida (gli esiti clinici a livello soggetto). Le schede complete dei cinque dataset sono nello schema SQL del catalogo, tra gli artefatti del repository (Appendice C).

Campo	Valore
URN	urn:novacura:clinical:ct_subject_outcomes
Nome	Esiti per soggetto negli studi clinici
Dominio	Studi clinici
Owner / Steward	Clinical Data Owner / Clinical Data Steward
Sensibilità	Restricted (PHI, GxP)
Formato / Location	Delta, s3://novacura-lake/gold/clinical/subject_outcomes (Gold)
Refresh	Giornaliero
Retention	25 anni (EU CTR 536/2014)
Policy applicate	POL-CLS-01, POL-ACC-01, POL-RET-01, POL-PRV-01

Tabella 7.2 - Esempio di scheda compilata.

7.2 Il modello di metadati

Lo standard minimo di metadati (RF-02) segue la tripartizione tecnico / business / operativo. Gli attributi obbligatori coprono i tre strati: senza di essi un dataset non è governabile. Il modello è reso dato nella tabella metadata_attribute (artefatto 02), così una query può verificare che ogni dataset attivo dichiari tutti i metadati obbligatori.

Strato	Metadati obbligatori (estratto)	Esempio
Tecnico	formato, versione schema, location fisica	delta, v3, s3://.../gold/lab/assay
Business	nome comprensibile, definizione, vocabolario di dominio	Misure di assay, ChEMBL
Operativo	owner, steward, sensibilità, refresh, retention, GxP	owner.lab, confidential, 15 anni

Tabella 7.3 - Modello di metadati per strato.

Il versioning dei metadati è implementato con un pattern append-only a validità temporale: un nuovo valore non sovrascrive il precedente, crea una nuova versione e chiude la vecchia. Così la domanda “quali metadati aveva questo dataset quando il modello fu addestrato?” ha sempre risposta, che è la base della riproducibilità.

Lo standard elenca esplicitamente quali attributi sono obbligatori e quali facoltativi, strato per strato. Un dataset attivo che non dichiara tutti gli obbligatori è un finding di governance, ed è ciò che una delle query di validazione (artefatto 05, controllo A2) verifica: lo standard è controllabile, non solo documentato.

Attributo	Strato	Obbligatorio
storage_format	Tecnico	sì
schema_version	Tecnico	sì
physical_location	Tecnico	sì
partition_keys	Tecnico	no
business_name	Business	sì
definition	Business	sì
domain_vocabulary	Business	no
unit_of_measure	Business	no
data_owner	Operativo	sì
data_steward	Operativo	sì
sensitivity	Operativo	sì
refresh_frequency	Operativo	sì
retention_period	Operativo	sì
gxp_relevant	Operativo	sì

Tabella 7.4 - Standard minimo di metadati: attributi obbligatori e facoltativi.

7.3 Vocabolari controllati e tag semantici

L'interoperabilità, in farmaceutica, non è opzionale: la stessa reazione avversa deve significare la stessa cosa in farmacovigilanza, in clinica e nel knowledge graph. I vocabolari standard sono il semantic layer reso persistente. Un tag semantico aggancia un campo del dataset a un termine di vocabolario, promuovendolo da colonna a concetto condiviso.

Vocabolario	Dominio d'uso
MedDRA	Reazioni ed eventi avversi (farmacovigilanza, clinica)
SNOMED CT	Termini clinici: diagnosi, reperti, procedure
MeSH	Indicizzazione della letteratura biomedica
ATC / ChEMBL	Classificazione e identità dei composti
Orphanet	Nomenclatura delle malattie rare
UniProt	Identità di proteine e target molecolari

Tabella 7.5 - Vocabolari controllati adottati.

Lettura critica. La scelta di un livello di indirezione tra tag interno e termine di vocabolario ha un costo (una join in più) e un beneficio preciso: MedDRA cambia versione due volte l'anno, e senza indirezione ogni aggiornamento toccherebbe il catalogo. Il disaccoppiamento tra semantica interna stabile e churn dei vocabolari esterni è ciò che rende il modello manutenibile nel tempo, non solo corretto all'origine.

7.4 Il ciclo di vita del dato

Catalogo e metadati non sono statici: accompagnano il dato lungo le cinque fasi del suo ciclo di vita, dall'acquisizione alla dismissione. La fase è evidenza, non teoria: ogni transizione (acquisizione con consenso e validazione all'origine, catalogazione con identità, uso con accesso controllato, archiviazione con retention, dismissione con anonimizzazione) va documentata, ed è proprio la documentazione a rendere il ciclo auditabile. La dismissione è la fase che i team saltano più spesso ed è quella con il bordo legale più netto: conservare dati personali oltre la finestra di retention non è inerzia neutra, è una responsabilità che cresce in silenzio. Per questo la cancellazione è un evento di catalogo, non un'operazione silenziosa sullo storage.

Mapa del ciclo di vita del dato

Cinque fasi (nota 04); la condivisione attraversa la vita attiva; owner - rischio - controllo



Figura 7.1 - Le cinque fasi del ciclo di vita, con la condivisione trasversale alla vita attiva e catalogo/lineage sotto ogni fase.

8. Data lineage e riproducibilità

Il lineage è la memoria del dato: da dove viene, come è stato trasformato, chi lo consuma. È la parte della tracciabilità che rende il ciclo di vita auditabile invece che solo descritto, e nel caso guida è il requisito più importante: consentire un audit completo dai dati grezzi al risultato del modello.

8.1 Il modello a grafo

La lineage è modellata come un grafo diretto (artefatto 03): i nodi sono asset o processi (sorgente, dataset, feature set, modello, output), gli archi sono trasformazioni prodotte da un'esecuzione di pipeline. La scelta del grafo non è estetica: una pipeline reale non è lineare. Il modello di repurposing consuma quattro fonti insieme (fan-in) e un dataset ne alimenta più di uno (fan-out); solo un grafo rappresenta queste relazioni multi-a-molti senza duplicazione.

Lineage end-to-end del programma di repurposing

Ingest - trasformazione - feature - modello - output, con i controlli di governance

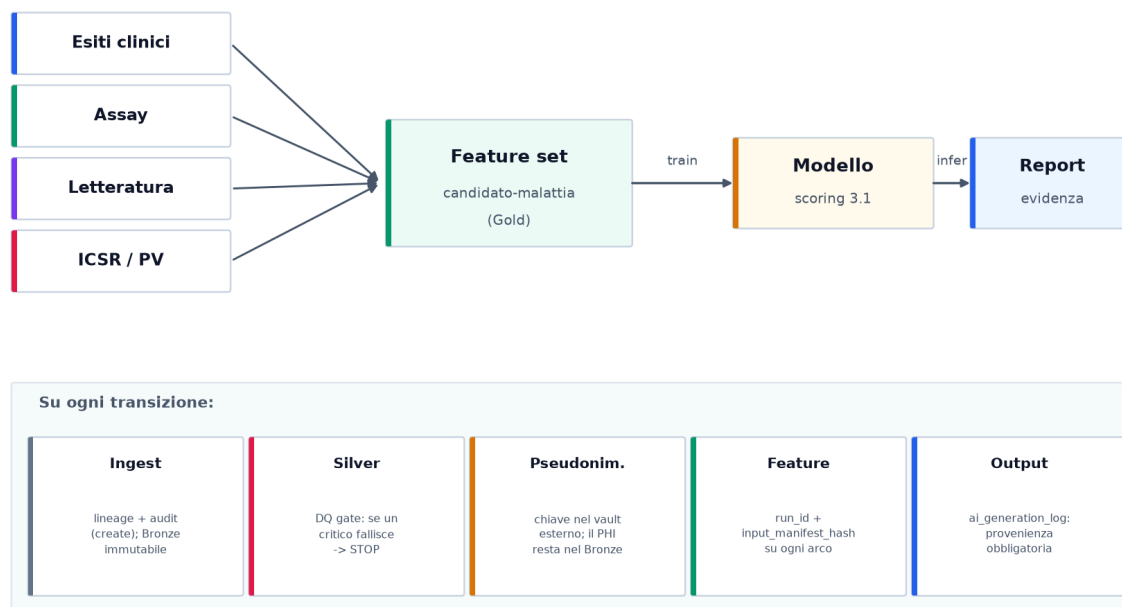


Figura 8.1 - Lineage end-to-end: le quattro fonti confluiscono nel feature set, poi modello e output, con i controlli di governance su ogni transizione.

8.2 Ricostruzione e riproducibilità

Registrare l'esecuzione (run) su ogni arco è la decisione che abilita la ricostruzione temporale. Ogni run porta la versione di codice e l'hash del manifest degli input: per rifare esattamente un risultato servono lo stesso codice e gli stessi input. In un contesto GxP questi non sono telemetria, sono evidenza ALCOA+. Le query ricorsive dell'artefatto 06 percorrono il grafo in due direzioni: all'indietro (da un output alle sue origini, la ricostruzione regolatoria) e in avanti (da una sorgente a ciò che ne dipende, l'analisi di impatto prima di modificare o ritirare un dato).

La query di ricostruzione firmata restituisce, per un dato output, l'elenco completo delle sorgenti con la run che le ha trasformate, la versione di codice, l'hash del manifest e chi l'ha lanciata.

Lettura critica. Le stesse due query ricorsive rispondono a domande opposte invertendo solo la direzione dell'arco percorso. È la prova che il modello a grafo è la rappresentazione giusta: una struttura, due letture. Il limite noto è la scalabilità su grafi enormi (lineage a livello di singola colonna su migliaia di trasformazioni), dove la ricorsione va vincolata; su una lineage di dominio, con profondità nell'ordine delle decine di hop, il costo è trascurabile.

9. Policy di data governance

Le policy sono la traduzione operativa dei principi in regole con un proprietario. Seguono la distinzione policy / standard / procedura: la policy dice cosa fare e perché, lo standard come, la procedura chi. Sono oggetti versionati con una data di efficacia, perché una policy che cambia non cancella la precedente: la ricostruzione regolatoria deve poter dire quale policy era in vigore alla data X.

La piattaforma definisce cinque policy aziendali di alto livello. Il testo completo di ogni statement, versionato e con owner, è nello schema SQL delle policy, tra gli artefatti del repository (Appendice C).

Codice	Titolo	Sintesi dello statement
POL-CLS-01	Classificazione dei dati	Quattro livelli; i dati a livello soggetto sono restricted per default
POL-ACC-01	Controllo degli accessi	RBAC con segregazione dei compiti; restricted solo a ruoli autorizzati, ogni accesso loggato
POL-RET-01	Conservazione dei dati	Retention per obbligo regolatorio per categoria (fino a 25 anni per gli studi)
POL-PRV-01	Privacy e pseudonimizzazione	Dati sanitari come categoria particolare (GDPR art. 9); pseudonimizzazione all'ingest
POL-SHR-01	Condivisione dei dati	Condivisione esterna: anonimizzazione validata e approvazione di Regulatory Affairs

Tabella 9.1 - Le cinque policy di data governance.

9.1 Classificazione e accesso

Lo schema di classificazione ha quattro livelli più due flag ortogonali: PHI per i dati sanitari personali (GDPR art. 9) e GxP per la rilevanza regolatoria. La classificazione non è decorativa: è ciò che la policy di accesso e il retrieval del RAG leggono per decidere chi vede cosa.

Livello	Contenuto tipico	PHI	GxP
Public	Dato pubblico o pubblicabile	no	no
Internal	Dato interno all'organizzazione	no	no
Confidential	IP, dati di studio aggregati, dati commerciali	no	sì
Restricted	Dato a livello soggetto (PHI) o safety identificabile	sì	sì

Tabella 9.2 - I quattro livelli di sensibilità.

L'accesso è basato sui ruoli (RBAC) con segregazione dei compiti: i dati restricted sono accessibili solo a ruoli autorizzati e ogni accesso, concesso o negato, è registrato.

9.2 Conservazione, privacy e condivisione

La retention non è mai “tenere tutto per sempre”. Ogni regola lega una categoria di dato a un periodo, una base legale e un'azione di dismissione. Nel contesto pharma i periodi sono lunghi e imposti da norma.

Categoria	Periodo	Base legale	Azione
Studio clinico	25 anni	EU CTR 536/2014; ICH GCP E6(R2)	Anonimizza
ICSR / farmacovigilanza	10 anni	GVP Module VI; Dir. 2001/83/EC	Anonimizza
Assay / laboratorio	15 anni	GLP; policy IP interna	Archivia a freddo
Letteratura	3 anni	Policy interna di knowledge refresh	Cancella

Tabella 9.3 - Regole di retention per categoria.

La privacy adotta pseudonimizzazione all'ingest e anonimizzazione per l'uso secondario: per l'analisi non serve identificare, serve distinguere. La condivisione esterna di dati di studio richiede anonimizzazione validata e approvazione di Regulatory Affairs. Il legame policy-dataset è esplicito (tabella policy_dataset_map): la query di validazione verifica che ogni dataset restricted sia coperto da una policy di accesso, una di retention e una di privacy. La copertura non è assunta, è controllata.

9.3 Ruoli e responsabilità

I ruoli DAMA sono tenuti distinti come vuole la disciplina: Data Owner (business, accountable), Data Steward (qualità), Data Custodian (infrastruttura), più i ruoli specifici del contesto AI e pharma. La segregazione owner/steward/custodian non è pedanteria: in una farmaceutica l'infrastruttura è spesso gestita da IT o da un fornitore esterno, mentre il significato del dato resta al business.

Ruolo	Natura	Responsabilità chiave
CDO	Strategico, apicale	Vision, framework, coordinamento; trasversale ai domini
Data Owner	Business, accountable	Definisce policy e accesso, priorità di qualità
Data Steward	Tecnico, operativo	Qualità, anomalie, metadati e lineage
Data Custodian	Infrastruttura	Storage, backup, meccaniche di accesso
Model Owner	AI / Data Science	Ciclo di vita del modello e dei suoi input
QA GxP / Regulatory	Quality / Regulatory	Validazione, audit, submission

Tabella 9.4 - Ruoli di governance.

10. Knowledge graph di dominio

Il knowledge graph è la conoscenza strutturata su cui poggiano la spiegabilità degli output e il grounding del RAG. La domanda centrale del repurposing è multi-hop: quali composti che agiscono su un target coinvolto in una malattia rara hanno già evidenza clinica o di assay, senza segnali di sicurezza ostativi? Sulle tabelle è una pila di join; sul grafo è una passeggiata lungo gli archi. La conoscenza densa di relazioni si modella come grafo, non come l'ennesima tabella larga.

Modello concettuale del knowledge graph

Entità biomediche, relazioni tipizzate ed evidenza reificata con provenienza



Figura 10.1 - Modello concettuale del knowledge graph: entità biomediche, relazioni tipizzate ed evidenza reificata.

10.1 Entità, relazioni ed evidenza reificata

I nodi rappresentano composti, target, malattie, trial, assay, eventi avversi, pubblicazioni ed evidenze; ogni tipo si aggancia a un vocabolario standard, così l'identità dei nodi è globale e non locale. La decisione di modellazione centrale è la reificazione dell'evidenza: un'affermazione come “sirolimus è candidato per la LAM” non è un fatto atomico ma è sostenuta da più fonti, con forza e direzione diverse, alcune a favore, alcune contrarie. Reificare l'evidenza in un nodo dedicato permette a ciascun pezzo di dichiarare la propria fonte, direzione e confidenza. È ciò che rende la spiegazione dell'output tracciabile fino al dato originale.

Elemento	Esempi
Nodi	Compound, Target, Disease, Trial, Assay, AdverseEvent, Publication, Evidence
Relazioni	targets, associated_with, repurposing_candidate_for, tests, reported_for
Ontologie di identità	ChEMBL, UniProt, Orphanet, SNOMED CT, MedDRA
Provenienza	prov:wasDerivedFrom su ogni nodo di evidenza

Tabella 10.1 - Elementi del knowledge graph.

10.2 Governance del grafo

Un knowledge graph senza ontologia deriva in un mess incoerente: la stessa relazione scritta in tre modi, entità duplicate. L'ontologia impone vincoli (un candidato al repurposing deve essere sostenuto da almeno un'evidenza a favore; indicated_for e repurposing_candidate_for sono disgiunti), che rendono il reasoning sano. La governance del grafo si esprime anche nello stato di validazione: ogni evidenza di origine automatica nasce 'proposed' e richiede la validazione di uno steward per passare a 'asserted'. Il RAG governato interroga solo il sottografo asserted.

Lettura critica. Il rischio del modello è il popolamento automatico dalla letteratura: un LLM che estrae relazioni introduce errori che, una volta nel grafo, diventano fatti autorevoli consumati dal RAG. La difesa non è la fiducia nell'estrazione ma la governance del grafo: stato di validazione, confidenza e fonte su ogni evidenza. Un grafo che accetta estrazioni non validate eredita il problema del “sembra giusto ma non lo è”, con l'aggravante di cristallizzarlo come conoscenza strutturata.

11. Flusso RAG governato

Il RAG è il canale che genera documentazione contestuale a partire da fonti verificate. Il principio del modulo è netto: un RAG è affidabile solo quanto la data governance dietro di esso. Il RAG è l'interfaccia; la governance è ciò che lavora dietro le quinte per renderlo affidabile, sostenibile e spiegabile. La lente qui non è come costruire un retriever ma quali documenti sono ammessi, chi può vederli, come la risposta cita la fonte e come si mantiene la freschezza.

Flusso RAG governato

Sette passi (nota 07) con i controlli di governance dove agiscono

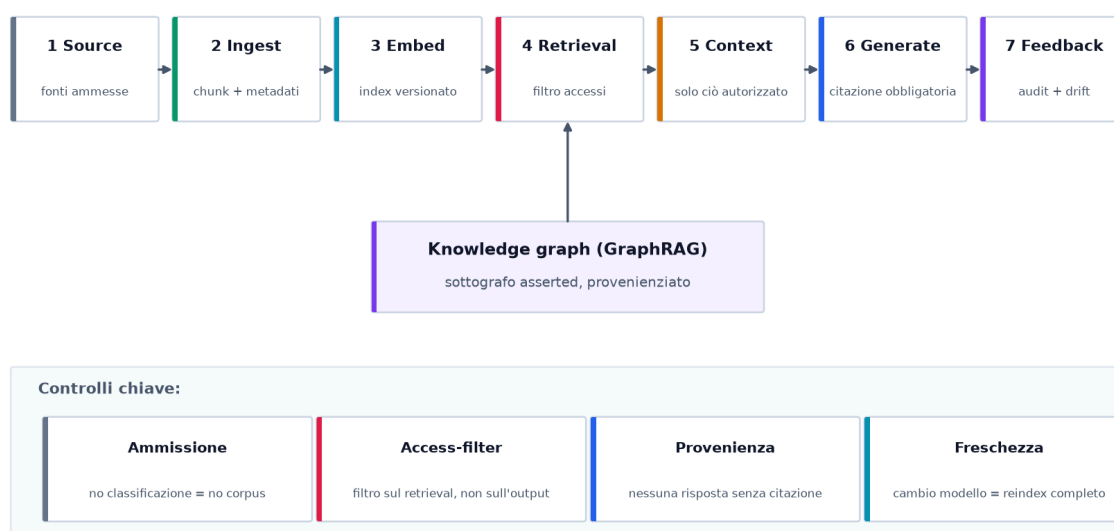


Figura 11.1 - Flusso RAG governato: sette passi con i controlli di governance dove agiscono e il grounding sul knowledge graph.

Due controlli distinguono questo flusso da una casella di ricerca. Il primo è il retrieval filtrato per accessi: il filtro sui permessi vive nel passo di retrieval, prima del ranking, non dopo la generazione. Se un chunk vietato raggiunge il modello, la fuga di informazione è già avvenuta, qualunque cosa dica il filtro sull'output. Il secondo è la citazione obbligatoria: ogni affermazione nomina la fonte, e lo schema del log (artefatto 04) impone a livello di vincolo che nessun output sia registrabile senza citazioni.

Il grounding sul knowledge graph (GraphRAG) è l'innesto che distingue il flusso da un RAG puramente vettoriale: oltre ai chunk testuali, il retrieval recupera un sottografo connesso e con provenienza chiara e definita. Il modello riceve fatti strutturati, non solo un sacco di paragrafi, con meno allucinazioni e provenienza per costruzione.

Controllo di governance	Dove agisce nel flusso
Qualità e validazione delle fonti	Passo 2 (ingest), prima dell'embedding
Controllo accessi	Passo 4 (retrieval) e passo 7 (log)
Gestione del ciclo di vita	Passo 3 (embedding) e passo 7 (feedback)
Provenienza e spiegabilità	Passi 5-6 (citazione) e grounding sul grafo

Tabella 11.1 - Controlli di governance mappati sui passi del flusso.

Lettura critica. Il punto più fragile è il confine tra retrieval filtrato e generazione: tutta la sicurezza poggia sul fatto che i permessi siano applicati prima che il contesto raggiunga il modello. Un solo percorso che inietti un chunk non filtrato trasforma l'assistente in un canale di esfiltrazione. Per questo il flag `access_filter_applied` è loggato e atteso sempre vero, e un valore falso è trattato come incidente di sicurezza, non come warning.

12. Audit, data quality e reportistica

12.1 Data quality sulle sei dimensioni

La qualità del dato è il principio portante reso misurabile. Sei dimensioni, ciascuna con un indicatore e una soglia fissata dal business, non dall'ingegnere. Le soglie vivono nella tabella `dq_rule` (artefatto 05) con il loro responsabile: sono dato, e cambiarle è un aggiornamento tracciabile, non un edit del codice.

Dimensione	Domanda	Come si misura
Completezza	Manca un valore essenziale?	% record popolati per un campo
Accuratezza	Il dato riflette il fatto reale?	% valori validati su fonte fidata
Consistenza	I dati concordano tra sistemi?	% record allineati tra sorgenti
Tempestività	Il dato è attuale quando serve?	Latenza media vs finestra richiesta
Unicità	Ci sono duplicati indesiderati?	% record duplicati

Dimensione	Domanda	Come si misura
Validità	Il dato rispetta formato e regole?	% valori conformi al pattern

Tabella 12.1 - Le sei dimensioni di data quality.

Lo score composito (1-100) con le bande a semaforo (rosso sotto 70, giallo 70-80, verde sopra 80) rende la qualità comparabile tra dataset. Ma un fallimento su una dimensione critica forza il rosso a prescindere dalla media: un dataset con endpoint primario incompleto non è “quasi buono”, è inutilizzabile per lo scopo. È l'argomento dell'effetto composto: nessuna dimensione da sola è catastrofica, ma l'insieme fallisce l'uso previsto.

12.2 Audit trail 21 CFR Part 11

L'audit trail rende ogni operazione ricostruibile a fini regolatori. Copre tre superfici: operazioni su dati e metadati, accessi, e il processo di generazione dei risultati AI. La proprietà chiave è append-only: un audit trail modificabile non è un audit trail. L'immutabilità è imposta a livello di schema da un trigger che blocca UPDATE e DELETE, e rafforzata da una catena hash in cui ogni evento incorpora l'hash del precedente, così una manomissione a posteriori spezza la catena ed è rilevabile.

Il log di generazione AI (ai_generation_log) è lo step di feedback del RAG reso governance: ogni output è loggato con la sua provenienza completa (chunk recuperati, sottografo KG, citazioni, versioni di modello e indice) e con il flag che prova che il filtro accessi è stato applicato prima della generazione. Risponde alla domanda regolatoria “perché il sistema ha dato questa risposta?”.

Lettura critica. Il vincolo di schema che impone almeno una citazione per ogni output loggato traduce in regola ciò che la nota sul RAG chiede come principio: nessuna risposta AI senza provenienza. Rende impossibile registrare un output non citato, quindi impossibile produrre uno “conforme” senza fonte. È la differenza tra una linea guida e un controllo: la prima si può aggirare per distrazione, il secondo no. Gli artefatti SQL a supporto di questo capitolo sono stati eseguiti su PostgreSQL, e il trigger di immutabilità è stato verificato rifiutando un tentativo di UPDATE sull'audit trail.

13. Supporto SQL e Big Data

La consegna include artefatti eseguibili. Gli artefatti SQL modellano il control plane della governance (catalogo, metadati, lineage, audit, qualità) e sono stati verificati caricandoli ed eseguendoli su un motore PostgreSQL. Gli artefatti Big Data specificano il data plane distribuito.

13.1 Artefatti SQL

File	Contenuto
01_data_catalog_schema	Catalogo: domini, ruoli, sorgenti, sensibilità, dataset, campi, policy, retention
02_metadata_model_schema	Modello di metadati: vocabolari, termini, tag semantici, attributi, versioning

File	Contenuto
03_lineage_tracking_schema	Lineage a grafo: nodi, archi, pipeline, run con versione di codice e hash del manifest
04_audit_trail_schema	Audit trail append-only, log accessi, log di generazione AI; catena hash e trigger di immutabilità
05_validation_queries	Controlli sulla governance (copertura policy, metadati mancanti) e sulla qualità (sei dimensioni, scoring)
06_lineage_reconstruction_queries	Query ricorsive: backward, forward e ricostruzione firmata per l'audit

Tabella 13.1 - Inventario degli artefatti SQL.

13.2 Specifiche Big Data

L'archetipo scelto è il lakehouse: integra dati strutturati, semi-strutturati e non strutturati su un piano economico, con transazioni ACID e governance uniforme. Un data warehouse puro rifiuterebbe testo e annotazioni; un data lake puro degraderebbe a swamp senza catalogo. Le transazioni ACID non sono un lusso: una scrittura parziale su un dataset GxP è un record incompleto, e un record incompleto viola ALCOA+.

Il partizionamento segue un principio: partizionare per le chiavi con cui si filtra e si applica la retention, non per quelle con cui si joina.

Dataset	Chiavi di partizione	Motivazione
Esiti clinici	study_id, snapshot_date	Si interroga per studio; retention alla chiusura
Assay	assay_type, run_date	Filtro per tipo; run a lotti datati
Letteratura	ingest_month	Volume incrementale mensile
Farmacovigilanza	receipt_year, seriousness	Reporting per anno; casi seri prioritari

Tabella 13.2 - Partizionamento logico dei dataset distribuiti.

Ogni dataset espone un manifest che ne dichiara schema, partizioni, metriche di qualità, sensibilità e riferimenti di lineage. Il suo hash è registrato sulla run di pipeline: è il punto di aggancio tra data plane e control plane, e verificare l'hash significa verificare che i dati non siano cambiati sotto il modello. Le pipeline sono specificate come pseudocodice non eseguibile con i checkpoint di governance espliciti a ogni stadio (ingest, DQ gate, pseudonimizzazione, feature, scoring, report, monitoraggio).

Il manifest è un artefatto compatto per costruzione; se ne riporta un campione (il dataset di assay) per rendere il documento autocontenuto. Le chiavi essenziali agganciano il file fisico al catalogo (dataset_urn, governance), alla qualità (dq_gate, score) e alla run che lo ha prodotto (lineage, code_version). Il manifest integrale è tra gli artefatti del repository (Appendice C).

```
{
  "dataset_urn": "urn:novacura:lab:assay_measurements",
  "physical": {
    "format": "delta", "medallion_layer": "gold",
    "location": "s3://novacura-lake/gold/lab/assay_measurements",
    "delta_version": 412, "file_count": 428 },
  "partitioning": { "keys": ["assay_type", "run_date"], "z_order": ["compound_id"] },
  "schema": {
    "schema_version": 3, "fields": [
      { "name": "compound_id", "type": "string", "semantic_tag": "compound",
        "vocabulary": "ChEMBL", "sensitivity": "confidential" },
      { "name": "value", "type": "double", "unit": "nM", "sensitivity": "confidential" } ] },
  "quality": { "dq_gate": "silver_to_gold", "overall_score": 99.4, "band": "green" },
  "governance": {
    "sensitivity_class": "confidential", "phi": false, "gxp_relevant": true,
    "policies": ["POL-CLS-01", "POL-ACC-01", "POL-RET-01"],
    "retention": { "period": "15 years", "disposal": "archive_cold" } },
  "lineage": { "produced_by_run": 1, "pipeline": "PIPE-REPURPOSE-01",
    "code_version": "a1b2c3d4" },
  "integrity": { "content_hash_algo": "sha256",
    "signed_by": "custodian.platform@novacura.example" }
}
```

Estratto 13.1 - Campione di manifest di dataset (chiavi essenziali; valori illustrativi).

La pipeline di repurposing è specificata in forma astratta e non eseguibile. Il flusso a sette stadi mostra dove la governance entra a ogni passo; il diagramma coglie le dipendenze di dato, non la schedulazione reale (ingest continuo, promozione batch e monitoraggio asincrono girano a cadenze diverse).

[1] INGEST	4 fonti -> Bronze (append-only)	gov: lineage(ingest) + audit
[2] CONFORM/CLEAN	Bronze -> Silver (dedup, vocabolari)	gov: DQ gate; se fail -> STOP
[3] PSEUDONYMIZE	Silver (chiave -> vault esterno)	gov: audit; PHI resta nel Bronze
[4] FEATURE	Silver x4 -> Gold feature_set (join)	gov: policy check; lineage fan-in
[5] SCORE	feature_set -> punteggi candidati	gov: lineage(infer) + model_version
[6] EVIDENCE	punteggi + KG + citazioni -> report	gov: ai_generation_log (provenienza)
[7] MONITOR	drift, freshness, bias -> feedback	gov: DQ dinamica + alert

Estratto 13.2 - Flusso astratto della pipeline PIPE-REPURPOSE-01.

```
JOB repurpose_evidence_aggregation(candidate, disease):
  run = gov.open_pipeline_run(pipeline, code_version, triggered_by) # ALCOA+: attributable
  ingest [clinical, lab, literature, safety] -> Bronze # gov.emit_lineage + audit
  for ds in bronze_datasets:
    silver = map_to_vocabularies(clean(ds)) # SNOMED / MedDRA / ChEMBL
    if not gov.run_dq_gate(silver).passed_critical: # DQ gate critico = STOP
      gov.close_run(run, "aborted"); STOP
  pseudonymize(silver where phi, key_ref=EXTERNAL_VAULT) # PHI filtrata a monte
  features = build_features(silver.clinical, assay, literature, pv) # fan-in x4 -> Gold
  gov.assert_policy_coverage(features) # Silver->Gold: policy o STOP
  scores = load_model(registry, version=PINNED).infer(features) # nessun training in-line
  for candidate in top(scores):
    ev = governed_rag(explain(candidate), acl=user.perms, kg_grounding=True)
    assert ev.citations != EMPTY # nessun output senza fonte
    gov.log_ai_generation(..., access_filter_applied=True) # provenienza obbligatoria
  gov.close_run(run, "succeeded", input_manifest_hash=hash(features.manifest))
```

Estratto 13.3 - Pseudocodice non eseguibile con i checkpoint di governance.

Lettura critica. Il rischio maggiore del lakehouse non è tecnico ma organizzativo: concentra dati di sensibilità molto diversa (letteratura pubblica e PHI a livello soggetto) su un solo piano. La separazione non può essere solo logica. La difesa è a tre livelli: Bronze identificabile isolato con accesso minimo, pseudonimizzazione obbligatoria alla promozione a Silver, e ACL con mascheramento di colonna applicati dal catalogo del lakehouse. Se anche uno solo salta, la comodità di un piano unico diventa una superficie di esfiltrazione unica.

14. Modello di maturità e roadmap di adozione

Un modello di maturità rende visibile il punto di partenza e la direzione. La scala va da 1 (ad-hoc, nessuna regola) a 5 (optimising, monitoraggio continuo con alert su drift e bias), valutata su sei dimensioni.

Modello di maturità e roadmap di adozione

Scala di maturità (nota 09) e adozione incrementale a tre wave



Figura 14.1 - Scala di maturità e roadmap di adozione a tre wave.

Dimensione	Punto di partenza tipico	Obiettivo
Data quality	2 - regole di base, pochi controlli automatici	4 - DQ gate automatici, metriche tracciate
Sicurezza e privacy	3 - auth forte, classificazione PHI debole	4 - RBAC + pseudonimizzazione governata
Ruoli e responsabilità	2 - owner e steward informali	4 - ruoli formali per dominio
Data lineage	2 - tracciamento parziale	4 - lineage ricostruibile end-to-end
Etica e bias	1 - nessuna analisi sistematica	3 - test periodici di fairness
Monitoraggio post-produzione	2 - solo accuratezza	4 - alert su drift e freschezza

Tabella 14.1 - Assessment di maturità e obiettivi.

La roadmap è incrementale a tre wave, coerente con la logica PoC-MVP-scala. Wave 1 (PoC): catalogo, classificazione e lineage su un solo dominio, per validare il design. Wave 2 (MVP): policy, DQ gate e RAG governato sul programma di repurposing, in esercizio su un caso reale. Wave 3 (scala): knowledge graph di dominio, audit degli output AI ed estensione agli altri domini di dato.

Lettura critica. Le due dimensioni più basse all'inizio (etica/bias e ruoli) sono il segnale da leggere: un sistema può sembrare sicuro e accurato mentre nessuno ne risponde e nessuno controlla chi discrimina. Per questo la Wave 1 parte da catalogo e ownership, non da capacità avanzate: senza un proprietario e una classificazione, ogni controllo successivo degrada a buone intenzioni.

15. Rischi e mitigazioni

I rischi rilevanti per una piattaforma di governance a supporto di AI in farmaceutica si concentrano su tre fronti: la protezione del dato sensibile, l'affidabilità della conoscenza che alimenta l'AI, e la tenuta organizzativa della governance nel tempo.

Rischio	P x I	Mitigazione
Esfiltrazione via RAG (retrieval non filtrato)	Bassa x Alto	Filtro accessi al retrieval, flag loggato, trattato come incidente
Conoscenza non validata nel KG (estrazione automatica)	Media x Alto	Stato proposed/asserted, validazione umana, confidenza e fonte
Staleness del corpus / indice	Media x Medio	Freshness con owner e cadenza, reindex su cambio modello
Manomissione dell'audit trail	Bassa x Alto	Append-only, trigger di immutabilità, catena hash
Deriva della governance nel tempo	Media x Medio	Policy e soglie come dato con owner; query di autoispezione
Re-identificazione di dati pseudonimizzati	Bassa x Alto	Chiave nel vault esterno, anonimizzazione per l'uso secondario

Tabella 15.1 - Mappa dei rischi principali e mitigazioni.

Lettura critica. La tensione di fondo non si risolve, si gestisce: l'innovazione rapida dell'AI contro il rigore della governance. La scelta di impianto è non trattarli come opposti. Il DQ gate che ferma la pipeline, la validazione umana sul grafo e il filtro accessi rallentano l'iterazione, ma sono ciò che rende un output difendibile davanti a un regolatore. Il costo è reale; il beneficio è che il progetto non si ferma per un audit fallito.

17. Appendici

Appendice A - Glossario

Termine	Definizione
ALCOA+	Principi di integrità del dato: Attributable, Legible, Contemporaneous, Original, Accurate, + Complete, Consistent, Enduring, Available

Termine	Definizione
Data lineage	Percorso documentato di un dato dall'origine, attraverso le trasformazioni, al consumo
GxP	Insieme delle Good Practice regolatorie (Clinical, Laboratory, Manufacturing)
ICSR	Individual Case Safety Report, il caso individuale di sicurezza in farmacovigilanza
Lakehouse	Architettura che unisce storage economico del lake e garanzie del warehouse (ACID, governance)
Medallion	Organizzazione dello storage in stadi Bronze, Silver, Gold di raffinamento crescente
PHI	Protected Health Information, dato sanitario personale (categoria particolare, GDPR art. 9)
Pseudonimizzazione	Sostituzione degli identificatori con pseudonimi, reversibile solo con una chiave separata
RAG	Retrieval-Augmented Generation: risposta di un LLM ancorata a contesto recuperato
Reificazione	Trasformazione di una relazione in un nodo, per appendervi proprietà e provenienza
Triple	Unità atomica del knowledge graph: soggetto - predicato - oggetto (RDF)

Tabella A.1 - Glossario dei termini.

Appendice B - Riferimenti normativi e standard

- **21 CFR Part 11** FDA, record elettronici e firme elettroniche.
- **EU Annex 11** Sistemi computerizzati in ambito GMP.
- **EU CTR 536/2014** Regolamento sugli studi clinici (conservazione dei dati).
- **ICH GCP E6(R2)** Good Clinical Practice.
- **GAMP 5** Approccio risk-based alla validazione dei sistemi computerizzati.
- **GVP Module VI** Good Pharmacovigilance Practices, gestione degli ICSR.
- **GDPR (Reg. UE 2016/679)** Protezione dei dati personali, art. 9 sulle categorie particolari.
- **EU AI Act** Regolamento sui sistemi di intelligenza artificiale.
- **DAMA-DMBOK** Corpo di conoscenza per il data management (ruoli, aree, processi).

Appendice C - Inventario degli artefatti e repository

Il documento riporta nelle sezioni pertinenti gli estratti rappresentativi degli artefatti: le policy e le regole di retention (capitolo 9), lo standard di metadati con obbligatori e facoltativi (capitolo 7), il campione di manifest, il flusso di pipeline e lo pseudocodice (capitolo 13). Gli artefatti integrali, versionati ed eseguibili (schemi SQL completi, campione RDF, manifest per esteso), vivono come file commentati nel repository pubblico del progetto. Gli schemi SQL sono stati caricati ed eseguiti su un motore PostgreSQL per verificarne la correttezza; le query di validazione e di ricostruzione restituiscono i risultati attesi sui dati seed, e il campione di triple è stato validato con un parser RDF. La tabella è l'inventario; il link a fine appendice porta alla cartella degli artefatti.

Percorso	Descrizione
artifacts/sql/01-06	Schemi e query del control plane (catalogo, metadati, lineage, audit, validazione)
artifacts/bigdata/partitioning_spec.md	Specifica di layout, partizionamento e formati del lakehouse
artifacts/bigdata/dataset_manifest_sample.json	Manifest campione di un dataset distribuito
artifacts/bigdata/pipeline_pseudocode.md	Pseudocodice non eseguibile della pipeline di repurposing
artifacts/knowledge_graph/kg_conceptual_model.md	Modello concettuale del knowledge graph
artifacts/knowledge_graph/kg_triples_sample.ttl	Campione di triple RDF (ontologia + istanze) validato con rdflib
artifacts/rag/rag_flow_spec.md	Specifica funzionale del flusso RAG governato
diagrams/00_generate_diagrams.py	Generatore delle otto figure del report

Tabella C.1 - Inventario degli artefatti consegnati.

Repository degli artefatti (pubblico):

https://github.com/Shurtug4l/AI_solutions_architect_course/tree/master/07_data_governance_knowledge_management/_PRJ_novacura_pharma_data_governance_platform/artifacts

Appendice D - Assunzioni

- L'azienda NovaCura Pharma e i dati usati negli esempi sono fittizi e illustrativi.
- Il caso sirolimus-LAM serve solo a rendere concreto il knowledge graph; le relazioni sono costruite per l'esempio.
- Gli artefatti SQL sono verificati su PostgreSQL 15+; le varianti Big Data (Delta/Spark) sono annotate ma non eseguite.
- Le retention e le basi legali riflettono l'ordine di grandezza degli obblighi pharma, da rivalidare caso per caso.
- Il documento è una specifica progettuale: non include implementazione operativa né configurazione di prodotti.